RED TEAM · INFORME EJECUTIVO DE SEGURIDAD

My File Server: 1

Resultados de la prueba de penetración sobre un servidor de archivos y su impacto en el negocio

CONFIDENCIAL Documento académico · entorno aislado y autorizado

Juan Francisco Ortega Jiménez

Matrícula 184918 · Ing. en Tecnologías de la Información · UPSLP

Docente: Mtro. Servando López Contreras

Contexto del engagement

Se evaluó la seguridad de un servidor de archivos corporativo simulado. El objetivo del ejercicio fue responder una pregunta de negocio: ¿qué tan expuesta estaría la información si un atacante alcanzara la red donde vive este servidor?

El servidor concentra tres servicios de compartición de archivos, lo que lo convierte en un activo crítico: si cae, cae la información que custodia.

Activo evaluado

Servidor de archivos (FTP · SMB · NFS)

Tipo de prueba

Caja negra sin información previa

Enfoque

Red Team cadena de ataque real

Resultado

Compromiso total acceso de administrador

Metodología aplicada

Un proceso estructurado en cinco fases (PTES · OWASP · MITRE ATT&CK) que reproduce cómo opera un atacante real.

I

Reconocimiento

Localizar el servidor y mapear su superficie de ataque.

II

Enumeración

Descubrir servicios, usuarios y configuraciones.

III

Explotación

Conseguir el primer acceso al sistema.

IV

Escalada

Elevar privilegios hasta administrador.

V

Evidencia

Demostrar el impacto y restaurar el entorno.

03 · NIVEL GENERAL DEL RIESGO

Riesgo global del activo

CRÍTICO

El servidor permite un compromiso total por parte de un atacante con acceso a la red.

root

Acceso logrado

Control administrativo total

7

Hallazgos

de BAJO a CRÍTICO

2

Severidad máxima

vulnerabilidades críticas

Hallazgos críticos

Kernel obsoleto

CRÍTICO

Software del sistema sin actualizar desde 2015: permite a un usuario común convertirse en administrador (Dirty COW).

Credenciales débiles

CRÍTICO

Contraseñas triviales y reutilizadas que abrieron la puerta de entrada al sistema.

Registros expuestos

ALTO

El directorio de bitácoras del servidor se compartía con la red, filtrando información sensible.

FTP vulnerable

ALTO

Un servicio FTP anticuado permitía leer y copiar archivos del sistema sin autenticación.

Escenario de impacto empresarial

Un compromiso a nivel administrador afecta las tres propiedades de la seguridad de la información:

C

Confidencialidad

CRÍTICO

Acceso de lectura a todo: documentos, contraseñas y datos corporativos quedan expuestos.

I

Integridad

CRÍTICO

Capacidad de alterar o falsificar archivos y de instalar puertas traseras sin ser detectado.

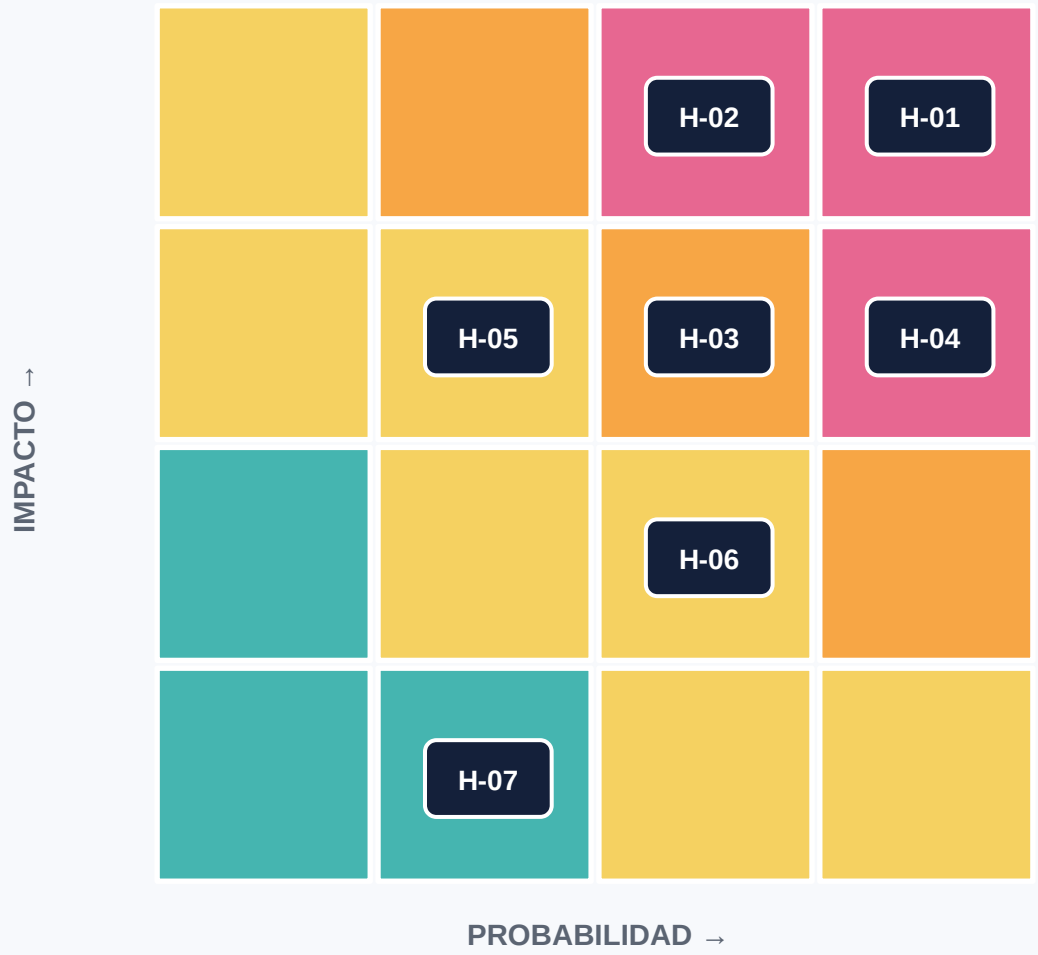
A

Disponibilidad

ALTO

Posibilidad de detener servicios, borrar información o desplegar ransomware.

Matriz de riesgo



Nivel de riesgo

- CRÍTICO
- ALTO
- MEDIO
- BAJO

Siete hallazgos ubicados según su probabilidad de explotación y su impacto. Los dos críticos (H-01, H-02) concentran la urgencia de remediación.

Recomendaciones estratégicas

Prioridad Inmediata

0 – 48 h

- Actualizar el sistema operativo (kernel).
- Rotar todas las contraseñas.
- Dejar de compartir los registros del sistema.

Prioridad Alta

1 – 2 semanas

- Actualizar y limitar los servicios FTP.
- Restringir los recursos NFS a equipos autorizados.
- Deshabilitar accesos anónimos.

Prioridad Sostenida

1 – 3 meses

- Endurecer el acceso remoto (SSH).
- Aplicar el principio de mínimo privilegio.
- Monitorear accesos y gestionar parches.

Roadmap de remediación

De “altamente vulnerable” a un estado defendible en tres etapas.

1

0–48 h

Contención

Eliminar las vías críticas: parches, credenciales y recursos expuestos.

2

1–2 sem

Corrección

Actualizar y endurecer los servicios de red.

3

1–3 meses

Madurez

Monitoreo continuo y gestión permanente de parches.

CONCLUSIÓN EJECUTIVA

El riesgo no vino de una sola falla, sino de la suma de varios descuidos.

Un registro compartido de más, una contraseña reutilizada, un servicio obsoleto y un sistema sin parchear bastaron para pasar de un simple acceso de red al control total del servidor. La buena noticia: cada eslabón es corregible, y el plan propuesto eleva de forma inmediata el nivel de seguridad del activo.

Juan Francisco Ortega Jiménez · Matrícula 184918

Fundamentos de Ciberseguridad · UPSLP · Docente: Mtro. Servando López Contreras